

ResolvX

TPRM ASSESSMENT REPORT

THIRD-PARTY RISK MANAGEMENT

RPT-TPRM-001 - v1.0 - July 2026 - Public - Client & Prospect Facing

ResolvX - Trust & Security Programme

Classification	Owner	Methodology	Review Cycle
Public	GRC Lead	Tiered TPRM (POL-005)	Quarterly

Executive Summary

ResolvX handles financial dispute data on behalf of regulated institutions, a responsibility that runs in two directions. We hold every vendor in our own supply chain to a formal risk-tiering and assessment standard. And when a prospective client evaluates ResolvX, they are doing exactly the same thing we do to our vendors which is assessing us as a third party with access to their data.

This report covers both directions. Part A explains how we manage third-party risk downstream, in our own vendor supply chain. Part B turns the same standard back on ResolvX, answering, domain by domain, the same categories of question our own Vendor Security Questionnaire asks of every vendor we onboard.

At a Glance

Downstream: 14 vendors under active management, 100% of Tier 1/Tier 2 formally assessed, 13/13 required DPAs executed.

Upstream: 26 policies covering every VSQ domain, SOC 2 Type II Fully Ready, ISO 27001 83% Implemented, 0 open audit nonconformities as of July 2026.

Part A - How We Manage Third-Party Risk

How ResolvX assesses, tiers, and monitors the vendors in its own supply chain.

1. How We Tier and Assess Vendors

Every vendor is tiered at onboarding based on the sensitivity of the data it can access and how central it is to ResolvX's operations.

Tier	Definition	Assessment Requirement
Tier 1 - Critical	Access to Restricted-tier data, or a single point of failure for core operations	Full assessment at onboarding, formally re-assessed annually, SOC 2 / ISO 27001 evidence required
Tier 2 - High	Access to Confidential/Internal data, or material operational dependency	Full assessment at onboarding, SOC 2 report reviewed at each renewal
Tier 3 - Medium	Limited data access, easily replaceable	Lighter-touch review at onboarding; reassessed if scope changes

Every assessment runs through the same Vendor Security Questionnaire (VSQ) covering governance, access control, data protection, vulnerability management, incident response, business continuity, sub-processors, and personnel security which is reviewed and scored by the GRC Lead, not self-certified by the vendor.

2. Vendor Portfolio at a Glance

Metric	Result
Total vendors under management	14
Tier 1 Critical / Tier 2 High / Tier 3 Medium	6 / 6 / 2
Tier 1 + Tier 2 vendors formally assessed	12 / 12 (100%)
Data Processing Agreements executed	13 / 13 required (100%)
SOC 2 coverage across Tier 1 & Tier 2	12 / 12 (100%)
Vendors with residual risk above Medium	0

Tier 3 vendors (Zoom, Notion) are intentionally outside the formal assessment cycle due to limited data exposure and easy replaceability mean the lighter-touch onboarding review already reflects our actual risk, not a gap in coverage.

3. Tier 1 Critical Vendor Assessments

Vendor	Score	SOC 2	ISO 27001	DPA	Next Review
AWS	94/100	Current	Certified	Executed	2027-01
Okta	90/100	Current	Not certified	Executed	2026-05
GitHub (Microsoft)	96/100	Current	Certified	Executed	2026-08
Google Workspace	95/100	Current	Certified	Executed	2026-12
Jamf	86/100	Current	Not certified	Executed	2026-02
1Password	92/100	Current	Not certified	Executed	2026-04

All six carry a Low-risk rating. Where a vendor lacks ISO 27001 certification (Okta, Jamf, 1Password), we treat a current SOC 2 Type II report as sufficient offsetting evidence and note it explicitly in the assessment record.

4. Sub-Processor Transparency & Data Residency

Sub-processor	Role	Data Location	Transfer Mechanism
AWS	Primary infrastructure — processes client dispute data	EU (eu-west-1 / eu-central-1)	DPA + EU SCCs
Okta	Staff authentication only — no client PII	US, EU residency option	DPA + EU SCCs
GitHub	Source code hosting — no client data permitted	US / EU	DPA + EU SCCs
Google Workspace	Internal comms — EU residency enforced	EU	DPA + EU SCCs
Datadog	Infrastructure monitoring — logs anonymised	US	DPA + EU SCCs

All production client data stays in the EU. Where a sub-processor is US-based, a Transfer Impact Assessment has been conducted, and Standard Contractual Clauses are in place. Clients are notified 30 days in advance of any new or replaced material sub-processor.

5. Ongoing Governance

- Vendor register and sub-processor register both reviewed quarterly, or immediately upon any material vendor change.
- Contracts approaching expiry (within 90 days) are flagged for renewal review before lapse.
- A vendor-caused security incident is handled through the same Incident Management process as an internal one.
- Vendor access is reviewed as part of the same quarterly access review cycle that covers internal systems.

Part B - ResolvX as Your Third Party

If you assessed ResolvX the way we assess our own vendors, here is how we'd answer the same domains our Vendor Security Questionnaire uses. Every figure below is drawn from our current internal audit, control matrices, and policy suite.

Governance & Security Programme

26 formal, version-controlled policies (POL-001–026) covering every domain from access control to exception governance, each with a named owner and annual review cycle. Information Security Policy approved at CISO level, establishing our ISMS and risk appetite. No material security incidents in the past 24 months requiring client notification.

Access Control & Identity Management

MFA enforced for 100% of users via Okta SSO. Privileged and admin accounts require FIDO2 hardware keys, not app-based MFA. Role-based access control with quarterly access reviews. Access is removed the same day employment ends with a quarterly dormant-account reconciliation as a second check.

Data Protection & Encryption

Four-tier data classification scheme (Public/Internal/Confidential/Restricted) with defined handling rules per tier. AES-256 encryption at rest, TLS 1.2 minimum (TLS 1.3 preferred) in transit, AWS KMS-managed keys with defined rotation. Data Loss Prevention scope and roadmap formally documented, with any residual coverage gap explicitly risk-accepted rather than left undisclosed.

Vulnerability Management

Continuous SAST/SCA scanning integrated into every CI/CD pipeline via Snyk, with automatic ticket creation on High/Critical findings. Formal remediation SLA by severity: Critical 7 days, High 30 days, Medium 60 days, Low 90 days. As of our most recent re-audit (2026-07-31), zero High-severity findings remain open past SLA.

Incident Response & Breach Notification

Documented Incident Response Plan with three operational runbooks (phishing, ransomware, data breach), a universal reporting obligation across all personnel, and a defined P1–P4 severity and notification framework. Two tabletop exercises on record: a ransomware scenario and a full DR/BCP failover exercise. Breach notification framework covers both EU (GDPR, 72-hour supervisory authority notification) and US (NYDFS, CCPA) obligations.

Business Continuity & Availability

Documented BCP/DR plan with RTO/RPO targets defined by asset criticality tier. Tested via a live DR failover tabletop exercise (July 2026), recovering within 98% of the Critical-tier RTO budget with data integrity independently verified before stand-down.

Personnel Security

Tiered background screening scaled to role sensitivity. Mandatory security awareness training at onboarding and annually thereafter, currently at 100% completion with automated escalation for anything overdue. Formal disciplinary process for policy violations, and confidentiality obligations that survive termination.

Sub-processors & Supply Chain

Covered in full in Part A above — the same disclosure and 30-day advance notification standard we apply, to how our own vendors are managed applies to, what we tell you about ours.

Current Certification & Audit Status

ISO 27001:2022 at 83% Implemented. SOC 2 Type II is Fully Ready (98%), auditor engagement in progress. NIST CSF 2.0 at 82/103 subcategories Implemented. Internal audit re-performed 2026-07-31: 0 major nonconformities, 0 minor nonconformities (down from 5), 2 observations remain — one an accepted, documented risk, the other tracked for a dedicated verification exercise. We show the gaps as readily as the certifications; a report with no open items would be less credible, not more.

What This Means For Our Clients

Your data is only as safe as the weakest vendor in our supply chain, and we know the same is true of us, in yours.

Every vendor with access to your data has been formally assessed, holds an executed DPA, and is reviewed on a defined cadence. And every claim we make about our own security in Part B is backed by the same kind of evidence we require from our vendors being a real audit, a real policy, a real tested exercise, not a checkbox. This is the same programme referenced in our Vendor Management Policy and reflected in our Trust Center.

Document Control

Document ID	Version	Date	Source Registers
RPT-TPRM-001	1.0	July 2026	TPRM Vendor Register, TPRM Subprocessors Register, TPRM Tier1 Assessment Reports